

6-3-2026

# Análisis comparativo de metodologías de seguridad informática

Parte I: Investigación comparativa de plataformas

**Nombre:**

**Morales Hernández Roberto Emiliano**

**Matrícula:**

**182377**

**Servando López Contreras**

**Grupo T46A**

## Investigación comparativa de plataformas

La gestión del riesgo humano ha evolucionado de un modelo de cumplimiento a uno de resiliencia. Para evaluar la efectividad de una plataforma, se toman en cuenta tres métricas fundamentales:

- **Click Rate (Tasa de Apertura/Clic):** Mide el porcentaje de usuarios que caen en la simulación. Aunque es la métrica más común, por sí sola es insuficiente para medir la cultura de seguridad.
- **Reporting Rate (Tasa de Reporte):** Es la métrica de éxito más crítica. Mide cuántos usuarios utilizaron las herramientas de reporte (botón de alerta) ante una amenaza sospechosa. Una alta tasa de reporte indica una cultura activa de defensa.
- **Risk Score (Puntuación de Riesgo):** Un algoritmo que combina el comportamiento histórico del usuario, su departamento y su rol para predecir la probabilidad de un incidente real.

### *El Enfoque Ético*

El diseño de estas plataformas debe basarse en el *refuerzo positivo* y el *consentimiento informado*. El objetivo no es "atrapar" al empleado para castigarlo, sino utilizar el momento de aprendizaje (teachable moment) justo después del error para educar sin generar conflicto o desconfianza hacia el departamento de TI.

### *Fundamentos de la simulación de phishing*

La simulación de phishing es una técnica utilizada dentro de los programas de **Security Awareness Training (SAT)** para evaluar el comportamiento de los usuarios frente a correos electrónicos maliciosos simulados. Estas campañas permiten medir el nivel de reconocimiento de amenazas de ingeniería social en una organización, evaluando cómo reaccionan los usuarios ante mensajes que imitan ataques reales como correos fraudulentos, enlaces maliciosos o solicitudes de credenciales.

A diferencia de los controles de seguridad puramente técnicos, como los filtros de correo o los sistemas de detección de intrusiones, las plataformas de simulación de phishing se enfocan en reducir la **superficie de ataque humana (Human Attack Surface)**. El objetivo es fortalecer la cultura de seguridad dentro de la organización mediante el entrenamiento continuo y la retroalimentación inmediata, permitiendo que los usuarios aprendan a identificar amenazas antes de que se conviertan en incidentes reales.

Dentro de este enfoque, la ingeniería social se reconoce como uno de los vectores de ataque más utilizados por los ciberdelincuentes. Según diversos reportes de seguridad, una gran proporción de brechas de seguridad comienzan con un correo electrónico de phishing. Por ello, las plataformas modernas de simulación no solo buscan medir errores, sino también promover comportamientos positivos mediante técnicas de **aprendizaje conductual**, micro-entrenamientos y refuerzo inmediato cuando el usuario identifica correctamente un intento de ataque.

En este contexto, el desarrollo de campañas de simulación de phishing debe realizarse bajo principios éticos, garantizando la privacidad de los usuarios y evitando enfoques punitivos que puedan generar desconfianza hacia el área de seguridad. Por ello, muchas plataformas modernas

adoptan modelos de **refuerzo positivo**, aprendizaje personalizado y anonimización de resultados individuales, asegurando que el objetivo principal sea educativo y no disciplinario.

## Plataformas

### Hoxhunt

**Enfoque:** Gamificación impulsada por inteligencia artificial.

**Descripción:** La plataforma utiliza algoritmos de aprendizaje automático para adaptar el nivel de dificultad de las simulaciones de phishing a cada usuario. En lugar de enviar campañas genéricas, el sistema analiza el comportamiento previo del empleado y genera correos simulados personalizados que evolucionan conforme el usuario mejora su capacidad de detección.



**Capacidades técnicas:** Hoxhunt se integra principalmente con entornos empresariales como Microsoft 365 y Google Workspace, permitiendo automatizar simulaciones continuas y recopilar métricas detalladas sobre el comportamiento del usuario frente a amenazas simuladas.

**Ética:** Se centra en la recompensa. Los usuarios ganan puntos y suben en un ranking global por reportar correos, eliminando el estigma del fallo.

### Proofpoint (PSAT)

**Enfoque:** Simulación basada en inteligencia de amenazas reales.

**Descripción:** Utiliza datos provenientes de su infraestructura global de seguridad de correo para crear simulaciones basadas en ataques reales observados en organizaciones. Esto permite que las campañas de entrenamiento reflejen amenazas actuales y relevantes.

The logo for Proofpoint is the word "proofpoint" in a lowercase, bold, sans-serif font. The "p" is significantly larger and more stylized than the other letters.

**Capacidades técnicas:** La plataforma se integra profundamente con el ecosistema de seguridad de Proofpoint, incluyendo soluciones de protección de correo electrónico, análisis de amenazas y herramientas de detección avanzada. Esto permite correlacionar el comportamiento del usuario con eventos de seguridad reales.

**Ética:** Enfoque basado en datos; identifica a los "Very Attacked People" (VAP) para darles protección y entrenamiento extra de forma proactiva.

## KnowBe4

**Enfoque:** Amplia biblioteca de contenido educativo y simulaciones de phishing.

**Descripción:** Ofrece una de las bibliotecas de contenido educativo más grandes del sector, con miles de plantillas de phishing, cursos de concienciación, vídeos y materiales interactivos. Esto con su programa “Kevin Mitnick Security Awareness Training”.



**Capacidades técnicas:** La plataforma permite automatizar campañas de phishing, medir la vulnerabilidad de los usuarios mediante el indicador **Phish-Prone Percentage** y generar reportes detallados sobre el nivel de riesgo organizacional.

**Ética:** Promueve la transparencia mediante un sistema de puntuación de riesgo que permite comprender cómo se calcula el nivel de vulnerabilidad del usuario.

## Cofense

**Enfoque:** Respuesta a incidentes impulsada por usuarios.

**Descripción:** Enfocado en convertir a los empleados en una red de sensores humanos que ayuden a detectar ataques de phishing reales. Su herramienta de reporte permite enviar correos sospechosos directamente al equipo de seguridad para su análisis.



**Capacidades técnicas:** La plataforma se integra con centros de operaciones de seguridad (SOC) y herramientas de automatización como SOAR, permitiendo analizar rápidamente los correos reportados y responder a incidentes potenciales.

**Ética:** Prioriza la detección sobre el engaño, entrenando al usuario, promoviendo una cultura organizacional en la que los empleados participan activamente en la defensa de la empresa.

## Phished

**Enfoque:** Automatización completa mediante inteligencia artificial.

**Descripción:** Uso de algoritmos de IA para diseñar automáticamente campañas de simulación de phishing sin necesidad de intervención constante de un administrador. La plataforma analiza el comportamiento de los usuarios y ajusta la frecuencia y complejidad de las simulaciones.



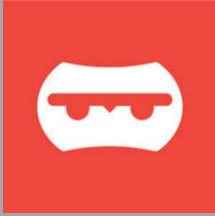
**Capacidades técnicas:** Ofrece integración con entornos corporativos de correo electrónico y plataformas de gestión de identidad, permitiendo ejecutar campañas de forma automatizada y analizar resultados en tiempo real.

**Ética:** Evita la fatiga de seguridad al no sobrecargar al usuario con simulaciones innecesarias si ya demuestran competencia.

## NINJIO

**Enfoque:** Micro-aprendizaje mediante narrativa audiovisual.

**Descripción:** Muestra de episodios animados cortos basados en incidentes reales de ciberseguridad. Cada episodio presenta situaciones cotidianas relacionadas con ingeniería social, permitiendo que los usuarios comprendan los riesgos a través de historias fáciles de recordar.



**Capacidades técnicas:** La plataforma se integra con sistemas de gestión de aprendizaje (LMS) mediante estándares como SCORM, permitiendo distribuir los contenidos dentro de programas corporativos de capacitación.

**Ética:** Utiliza la empatía y el "storytelling" para educar, evitando el lenguaje técnico complejo.

## Mimecast Awareness Training

**Enfoque:** Entrenamiento continuo integrado con la seguridad del correo electrónico.

**Descripción:** Se combinan simulaciones de phishing con contenido educativo basado en humor y situaciones cotidianas. Sus campañas suelen utilizar personajes y escenarios recurrentes que facilitan la retención del mensaje de seguridad.

**mimecast**

**Capacidades técnicas:** La plataforma se integra de forma nativa con el gateway de correo de Mimecast, permitiendo correlacionar simulaciones de phishing con eventos de seguridad detectados en el entorno de correo electrónico.

**Ética:** Enfoque no punitivo; se basa en la premisa de que la seguridad debe ser parte de la conversación diaria de forma amena.

## Mimecast Awareness Training

**Enfoque:** Rutas de aprendizaje personalizadas basadas en el rol del usuario.

**Descripción:** Ofrece una amplia biblioteca de recursos educativos y permite diseñar programas de capacitación alineados con marcos de cumplimiento como NIST, ISO 27001 y PCI-DSS.

**INFOSEC IQ**

**Capacidades técnicas:** La plataforma incluye herramientas de análisis predictivo que permiten identificar tendencias de riesgo humano dentro de la organización y adaptar el contenido de entrenamiento según el perfil del usuario.

**Ética:** Permite una personalización extrema para que el contenido sea relevante al rol del usuario, evitando entrenamientos irrelevantes.

| <b>Criterio</b>                 | <b>Hoxhunt</b>                   | <b>Proofpoint</b>        | <b>Knowbe4</b>          | <b>Cofense</b>           | <b>Phished</b>       | <b>NINJIO</b>            | <b>Mimecast</b>         | <b>Infosec iq</b>    |
|---------------------------------|----------------------------------|--------------------------|-------------------------|--------------------------|----------------------|--------------------------|-------------------------|----------------------|
| <b>Tipo de simulación</b>       | IA adaptativa                    | Amenazas reales          | Plantillas masivas      | Reporte SOC              | Automatizada         | Educativa                | Integrada correo        | Personalizada        |
| <b>Métricas principales</b>     | Click / Report Score             | VAP Risk                 | Phish-Prone %           | Report Rate              | Behavior Score       | Engagement               | Awareness Score         | Predictive Risk      |
| <b>Analítica</b>                | Alta                             | Muy alta                 | Alta                    | Media                    | Media                | Baja                     | Media                   | Alta                 |
| <b>Integración tecnológica</b>  | Microsoft 365                    | Ecosistema Proofpoint    | AD / SIEM               | SOC / SOAR               | Google / M365        | LMS (SCORM)              | Gateway Mimecast        | LMS / API            |
| <b>Enfoque de entrenamiento</b> | Gamificación                     | Inteligencia de amenazas | Contenido educativo     | Respuesta a incidentes   | Automatización IA    | Storytelling             | Humor educativo         | Rutas personalizadas |
| <b>Enfoque ético</b>            | Recompensa                       | Protección VAP           | Transparencia           | Empodera miento          | No intrusivo         | Empatía                  | No punitivo             | Relevancia por rol   |
| <b>Limitaciones</b>             | Requiere base grande de usuarios | Alto costo               | Administración compleja | Menos contenido creativo | Menor control manual | No simula ataques reales | Dependencia del gateway | Curva de aprendizaje |

## Análisis y Conclusión

Podemos definir que no existe una mejor plataforma de forma absoluta, sino que su elección depende del **contexto de uso**:

- ✓ **Para organizaciones con un SOC maduro:** *Cofense* o *Proofpoint* son ideales por su capacidad de integrar el reporte del usuario con la respuesta a incidentes.
- ✓ **Para PYMES o equipos de TI limitados:** *Phished* u *Hoxhunt* ofrecen la mejor eficiencia gracias a su automatización por IA.
- ✓ **Para cambiar la cultura desde el entretenimiento:** *NINJIO* y *Mimecast* destacan por su alto nivel de retención gracias al contenido audiovisual.

La **ventaja competitiva**, proviene de la tendencia actual que se aleja de la simulación "trampa" hacia la simulación "educativa". Las plataformas que integran IA (*Hoxhunt*, *Phished*) presentan una ventaja clara en la reducción del error humano al personalizar la dificultad, evitando que los usuarios expertos se aburran y los novatos se frustren.

Por lo que una **consideración ética** debe ser que cualquier plataforma elegida debe garantizar que los resultados individuales sean tratados con confidencialidad (Privacy by Design), asegurando que el simulacro sea una herramienta de crecimiento profesional y no una métrica para despidos o sanciones.

Observando como las plataformas modernas de simulación de phishing han evolucionado hacia modelos centrados en el comportamiento humano, donde el objetivo principal no es únicamente medir errores, sino desarrollar una cultura organizacional de seguridad. La elección de una plataforma debe considerar tanto sus capacidades técnicas como su impacto en la cultura de seguridad de los usuarios.

## Referencias bibliográficas

- Cofense. (2023). *The 2023 Annual State of Phishing Report*. <https://cofense.com/state-of-phishing-2023/>
- Gartner. (2022). *Magic Quadrant for Security Awareness Computer-Based Training*. Gartner Inc.
- Hoxhunt. (2024). *The Science of Behavior Change in Cybersecurity*. <https://www.hoxhunt.com/platform>
- KnowBe4. (2023). *2023 Phishing by Industry Benchmarking Report*. <https://www.knowbe4.com/phishing-benchmark-analysis>
- Proofpoint. (2024). *State of the Phish 2024*. <https://www.proofpoint.com/us/resources/threat-reports/state-of-phish>
- Infosec Institute. (2024). Infosec IQ security awareness training platform.

- Mimecast. (2024). Security awareness training platform. <https://www.mimecast.com>
- NINJIO. (2023). Cybersecurity awareness training platform. <https://ninjio.com>
- Phished. (2024). AI-driven security awareness training platform. <https://phished.io>